

The Procedural Semantics Gap in ATT&CK-in-STIX: Measuring Procedural Sufficiency for APT Emulation

Ágney Lopes Roth Ferraz*
Aeronautics Institute of Technology
São José dos Campos, SP, Brazil
roth@ita.br

Murray Evangelista de Souza
Aeronautics Institute of Technology
São José dos Campos, SP, Brazil
murraymes@ita.br

Sidnei Barbieri*[†]
Carnegie Mellon University
Pittsburgh, PA, USA
sbarbier@andrew.cmu.edu

Lourenço Alves Pereira Júnior
Aeronautics Institute of Technology
São José dos Campos, SP, Brazil
ljr@ita.br

Abstract

The public MITRE ATT&CK content serialized in Structured Threat Information Expression (STIX) has become a global reference for describing adversary behavior. However, ATT&CK was created as a descriptive knowledge base rather than a procedural model. This raises the question: does ATT&CK-in-STIX provide enough behavioral detail to support multi-stage adversary emulation? This paper presents the first systematic measurement of that procedural sufficiency boundary in public ATT&CK-in-STIX. Analyzing the ATT&CK Enterprise bundle, we find that campaign objects encode fragmented behavioral segments: only 43.0% of techniques appear in at least one campaign, and neither clustering nor Longest Common Subsequence (LCS) analysis reveals reusable procedural structure. Intrusion sets cover a broader portion of the technique space, but still lack ordering, preconditions, and environmental assumptions. As a result, public Cyber Threat Intelligence (CTI) describes *what* adversaries do, but not enough of *how* to automate those behaviors.

To examine how far explicit translation can bridge this gap, we introduce a three-stage methodology for converting descriptive CTI into executable adversary-emulation workflows, combining structural CTI modeling, analyst-curated technique translation, and workflow integration in the MITRE Caldera framework. Case studies of *ShadowRay* and *Soft Cell* campaigns demonstrate that structured CTI can support multi-step adversary enactment only after missing parameters and assumptions are supplied and validated. We also deployed a Docker-based environment with attackers and targets to emulate eight randomly selected campaigns and demonstrate the methodology’s feasibility. These results establish a reproducible boundary between the behavioral information encoded in public CTI and the procedures that must still be provided prior to execution. They clarify the role of descriptive CTI as a bounded input to intelligence-driven emulation, rather than as a coverage label. All code and data from this study are available at GitHub¹, to enable full reproducibility.

1 Introduction

Advanced Persistent Threats (APTs) unfold as multi-stage campaigns that may span multiple hosts, adapt to the target environment, and often rely on “living-off-the-land” techniques to blend with legitimate activity [4]. Their distributed, low-signal activities [44] and prolonged dwell times [29] make end-to-end reconstruction challenging in Security Operations Centers (SOCs) [9, 16, 27].

Provenance-based detection and learning-driven approaches illustrate why this challenge persists. Reconstructing multi-step behaviors leads to dependency explosion and produces large provenance graphs with multiple roots [8, 19, 20, 42]. These approaches also show that short or synthetic traces fail to capture characteristic APT dependencies [18, 29, 44].

Cyber Threat Intelligence (CTI) provides structured accounts of adversary tactics and techniques. Public feeds display heterogeneous formats, uneven granularity, and inconsistent field usage [22, 41]. Extracting actionable information from narrative reports requires substantial manual effort [35], and most CTI sources lack the procedural context and environmental constraints necessary for reproducible multi-host emulation [41]. There are even some discrepancies between different vendors’ reports. Analyses of intrusion-detection rules further reveal rapid turnover, skewed alert distributions, and weak links between rules, alerts, and incidents [43]. As a result, CTI is used primarily for mapping and coverage, but rarely as a direct source of executable adversary actions.

The MITRE ATT&CK framework offers a widely adopted taxonomy of tactics and techniques, disseminated as Structured Threat Information Expression (STIX) bundles employed by defensive platforms [30, 40, 45]. MITRE distributes ATT&CK datasets for Enterprise (Windows, Linux, network devices, etc.), Mobile (mobile operating systems, protocols, and infrastructure), and Industrial Control Systems (ICS) domains, all encoded in STIX. These bundles combine campaigns, intrusion sets, malware, tools, and relationships, but campaign and intrusion-set entries rarely encode temporal or causal information. Execution order, prerequisites, and environmental assumptions typically appear only in free text [30, 35, 41]. Previous work has either extracted partial behaviors from textual intelligence without producing executable actions [7, 35, 48], or reconstructed long-duration campaigns from telemetry [8, 42, 44]. Whether ATT&CK-in-STIX provides enough

*These authors contributed equally to this work.

[†]Also with Aeronautics Institute of Technology.

¹<https://anonymous.4open.science/r/sticks-5BC2/>

procedural detail to support APT emulation remains an open question.

We focus on the Enterprise bundle because, among the public STIX sources we parsed, it preserves the richest campaign-level structure. In our corpus, it is the source that most consistently combines campaigns, intrusion sets, techniques, and relationships into a single bundle. Unfortunately, the reusable procedural structure is still weak, so it is unlikely to be stronger or more consistent in sparser, more heterogeneous feeds. Our claims, therefore, apply to public ATT&CK-in-STIX bundles rather than to proprietary or internally enriched CTI repositories. This distinction is important as security teams and platform developers increasingly rely on structured CTI not only for coverage mapping but also for reproducible adversary emulation and defense validation.

Frameworks such as MITRE Caldera, a platform for adversary emulation and automated campaign (operation) orchestration, provide an execution substrate for emulating adversary behavior. However, translating CTI into runnable procedures still requires explicit planning, parameter binding, and a declared *System Under Test (SUT)* [38, 47]. We target analysts, emulation engineers, and artifact authors who seek to use public, structured CTI for more than just a coverage label. In our setting, the input is publicly available structured CTI and a declared SUT, and the desired output is an executable workflow along with an explicit record of what the CTI did not provide. Success is defined not by historical replay but by a reproducible separation between the behavioral structure already encoded in the CTI and the procedure that must still be added before execution. This framing motivates the research questions of this study:

RQ1: How much adversarial behavior do current ATT&CK-in-STIX artifacts capture for multi-step APT emulation?

RQ2: How can structured CTI be transformed into computable multi-stage behavioral plans for emulation?

RQ3: Which structural and semantic gaps in descriptive CTI prevent automation, and how can they be mitigated?

This paper makes three contributions: ① we measure coverage, sparsity, overlap, and clustering in the MITRE ATT&CK Enterprise bundle, and show from the bundle structure that campaign objects expose narrow, heterogeneous slices of behavior lacking ordering, preconditions, and environment bindings required for multi-stage execution; ② we define a three-stage translation methodology that automatically converts descriptive CTI into executable adversary-emulation workflows; and ③ we redefine that boundary with two focal case studies and an full docker environment with eight auditable campaigns, distinguishing reproducible execution progress from campaign-isolated replay. The companion artifact provides both the measurement pipeline and the Docker-audit surfaces supporting these claims.

Together, these contributions redefine the boundary of reproducible automation from public ATT&CK-in-STIX, as shown in Figure 1, and clarify its role as a behavioral grounding for emulation rather than as a directly executable procedure.

2 Background

CTI refers to evidence-based knowledge about cyber threats, ranging from low-level artifacts (Indicators of Compromise - IoCs)

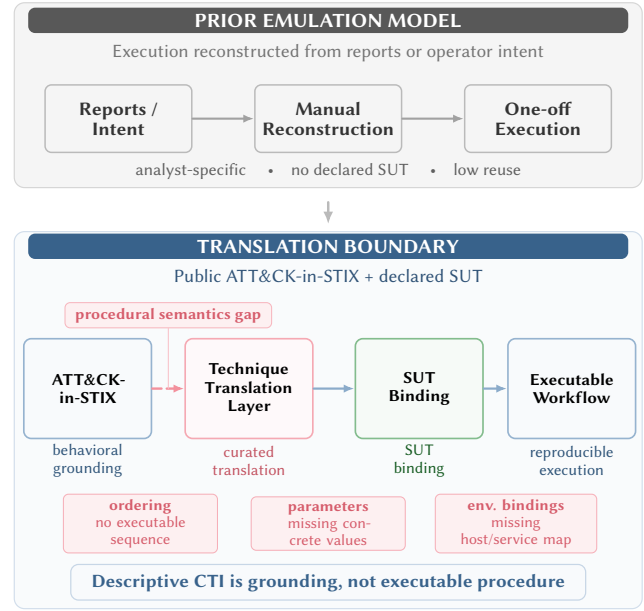


Figure 1: From descriptive CTI to executable emulation: public ATT&CK-in-STIX provides behavioral grounding, but not procedural executability, requiring explicit technique translation and binding to the system under test (SUT).

to structured descriptions of tactics, techniques, and procedures (TTPs). In its unstructured form, CTI appears as narrative reports, blog posts, and vendor documents, all of which require manual normalization before systematic use. The STIX standard was introduced to address this heterogeneity by representing threat entities and their relationships in a machine-readable format [30]. For this study, we focus on the STIX object types attack-pattern, campaign, intrusion-set, malware, tool, and relationship. Although these objects represent behavioral entities and their associations, they do not encode the procedural semantics of a campaign, including ordering, dependencies, parameters, and execution context. Alternative structured models, such as the Malware Information Sharing Platform (MISP) and the Cyber-investigation Analysis and Standard Expression (CASE), embody distinct trade-offs between simplicity and expressiveness that directly affect their ability to represent the procedural aspects of threat intelligence. We focus on ATT&CK-in-STIX because it is the most widely adopted public standard for representing adversary behavior in cross-organizational CTI exchange and threat-informed defense [22, 30].

MITRE maintains the ATT&CK framework as a hierarchical knowledge base of TTPs observed in real campaigns, organized into matrices for different domains (Enterprise, Mobile, and ICS) [40]. In this taxonomy, *tactics* represent objectives, while *techniques* and *sub-techniques* describe modes of operation. Beyond the matrix, ATT&CK also indexes threat groups, campaigns, malware, tools, telemetry sources, and mitigations [40]. MITRE publishes this content as STIX bundles built from object types

such as attack-pattern, intrusion-set, campaign, malware, tool, and relationship.

These conceptual layers serve distinct roles. ATT&CK defines the ontology of adversary behavior; STIX provides the serialization language; and the Enterprise bundle is one specific STIX export within the broader CTI ecosystem. In ATT&CK, each technique or sub-technique is represented by an attack-pattern object with fields such as description, kill-chain phases, external references, and tactic mappings. These objects are the primary building blocks used by extraction pipelines to align narrative reports with standardized technique identifiers [5, 35, 41].

Objects of type campaign represent specific operations attributed to a threat actor. They typically encode time windows, objectives, targeted sectors, and a subset of associated techniques, malware, or tools. In practice, however, CTI feeds rarely enumerate all steps, prerequisites, or action sequences. Threat reports often omit steps, merge phases, or present only fragments of the intrusion [35], and large-scale studies report inconsistent field usage and heterogeneous practices across providers [22]. As a result, campaigns encoded in STIX tend to lack the procedural specificity required for direct replay.

Objects of type intrusion-set aggregate the longer-term behavior of a threat group across multiple campaigns, including commonly used malware, techniques, infrastructure, and motivations [1]. In open STIX collections, campaigns are linked to intrusion sets via relationship objects that encode associations with attribution, tool usage, or techniques. This modeling reflects a common CTI distinction: *intrusion sets* capture the persistent adversary profile, while *campaigns* represent concrete operational instances. Even so, actor and technique labels remain inconsistent across vendors, which reduces interoperability [43].

Despite its broad adoption, the STIX data model was designed to describe threat entities and relationships, not to automatically reconstruct multi-host adversary behavior [30]. Although ATT&CK-in-STIX provides structured identifiers for techniques, tactics, campaigns, and intrusion sets, it does not directly encode temporal order, explicit prerequisites, environmental constraints, or branching logic. Relationship objects can state that an intrusion set “uses” a malware family or that a campaign is “attributed to” a group, but they do not specify how to sequence those entities into an execution plan. Prior work has used STIX and ATT&CK to construct behavioral graphs, align reports with technique identifiers, and organize threat entities, but these representations stop short of testing whether the resulting structures contain enough procedural semantics for executable multi-stage emulation [35, 40, 41]. Our work fills this gap by shifting the question from entity linkage to procedural sufficiency: we measure what public ATT&CK-in-STIX encodes, identify what remains absent, and show how those missing elements must be supplied before execution.

Open CTI collections also exhibit low coverage, delayed sharing, uneven field usage, and inconsistent labels [22, 43]. Extraction pipelines can recover partial behaviors from reports, but do not yield executable sequences with preconditions, parameters, control logic, or SUT bindings [5, 7, 13, 35, 41, 48]. Even when using emulation tools such as Caldera, CTI descriptions must still

be transformed into ordered, parameterized plans, and current artifacts provide no formal SUT abstraction tying techniques to the environments in which they are expected to execute [36, 38, 45].

3 Related Work

Recent advances in structured threat intelligence, technique extraction, and adversary emulation have expanded the methodological landscape. Prior work examines the structure and quality of CTI feeds published in STIX, evaluating aspects such as heterogeneity, coverage, field consistency, and the impact on commercial platforms and detection systems [22, 30, 36, 40, 41, 43, 45]. These studies reveal that both ATT&CK-annotated rules and other STIX sources exhibit uneven coverage and vendor-specific practices. However, they do not address whether a public STIX bundle contains sufficient procedural information to support multi-host emulation without analyst intervention. The question of procedural sufficiency within the bundle remains unexamined.

A parallel body of research focuses on extracting adversary behavior from unstructured text, including Extractor [35], CTI HAL [11], NLP-based pipelines [5, 7, 17, 48], and Large Language Model (LLM)-driven command and script reasoning [13]. These approaches advance the identification and organization of techniques, entities, and relationships, using supervised and weakly supervised extraction, SoK-style evaluations, and knowledge graph construction. Nonetheless, they evaluate extraction quality rather than the completeness or procedural sufficiency of what is encoded in STIX itself. Temporal relationships and execution conditions are inferred from narrative text rather than from the bundles’ object structure.

Closer to our framing, Saha et al. [34] analyze the distinctiveness of public threat-group profiles for attribution. They find that only a minority of ATT&CK groups have group-specific techniques, and that software often provides stronger group-level signatures than techniques alone. Our focus is complementary: we study campaign and intrusion-set profiles within the Enterprise bundle, computing exact positive-evidence witnesses and subsumption cases. We then ask whether the underlying STIX representation contains the procedural semantics required for execution, even when profiles are sufficiently distinctive for attribution. Their work highlights the limits of attribution specificity; ours addresses the limits of procedural sufficiency for emulation.

In detection and investigation, telemetry and provenance-based systems use ATT&CK as an annotation taxonomy but reconstruct attack structure from logs rather than from CTI. Provenance-based detectors such as HOLMES, UNICORN, and ATLAS [1, 18, 29], followed by ALchemist and NODLINK [25, 50], demonstrate the utility of whole-system audit data for reconstructing APT campaigns. Later work on provenance graph learning and scalable detection, such as Flash, Kairos, DistDet, PROGRAPHER, and ProvG-Searcher [2, 8, 15, 42, 49], improves efficiency and search over large graphs.

Other research addresses tactic and technique recognition or online segmentation, as in TREC, TAPAS, SLOT, and OCR-APT [3, 26, 33, 51], or targets lateral movement detection in temporal network graphs [23, 24]. Complementary measurements

highlight operational aspects of provenance-based EDR and auditing, including costs, triage, and logging limitations [14, 21]. These works provide detailed visibility into campaign behavior and operational constraints, but reconstruct attack chains from telemetry rather than from CTI object structures.

Adversary emulation frameworks such as Laccolith [32], PentestGPT [12], PentestAgent [37], and language model-driven proposals for offensive planning and cyber deception [38, 39] base their evaluations on curated procedures, environment models, and explicit execution logic specifying ordering, preconditions, and cleanup. Their experiments operate on fixed, parameterized, or benchmarked SUTs, rather than deriving procedures or environments directly from STIX bundles. This demonstrates that reproducibility depends on detailed behavioral descriptions and explicit SUT specification. For example, PentestGPT studies LLM-guided offensive interactions on benchmark targets, while InCALMO evaluates multi-host planning and execution through an explicit task abstraction and execution layer.

Standardization efforts are converging in a similar direction: OASIS CACAO playbooks [31] provide a shareable format for security workflows, and MITRE CTID Attack Flow [6] explicitly represents flows of ATT&CK techniques. Our work is more focused and more diagnostic: we ask what portion of the procedural burden can be derived from STIX itself, prior to any analyst or model-assisted translation. Structured CTI provides technique identifiers and behavioral context, but still requires further translation before it can be executed as a multi-stage procedure. We therefore evaluate the extent to which current STIX-encoded ATT&CK data contains, or omits, the procedural semantics needed for machine-actionable emulation.

Frameworks that operationalize adversary behavior clarify what structured CTI can and cannot provide. Planning-based systems, such as AURORA [47], model actions in terms of explicit preconditions and effects. The Effects Language (EL) formalism [10] shows that executable coordination demands ordering and guarded effects. Knowledge graph approaches like KNOWHOW [28] and MultiKG [46] enrich CTI with structure derived from telemetry or cross-source aggregation. These systems rely on procedural elements such as ordering, parameters, bindings, and environment assumptions that are not encoded in the current MITRE ATT&CK Enterprise bundle. Our methodology is therefore complementary: it identifies which procedural information is missing from this bundle and shows how descriptive CTI can be mapped to representations suitable for multi-host emulation, while explicitly specifying what current standards do not automate. To our knowledge, no prior work treats the ATT&CK Enterprise bundle itself as the object of measurement to assess its suitability for machine-actionable, multi-step emulation.

4 Data Sources

Our analysis draws on two main components: the structural properties of STIX objects representing intrusion sets, campaigns, and techniques, and a set of quantitative measures derived from binary representations of technique usage. In the MITRE ATT&CK Enterprise dataset, adversary behavior is modeled as a heterogeneous graph of typed objects. The main behavioral entities considered are

attack-pattern (techniques and sub-techniques), x-mitre-tactic (tactics), campaign, intrusion-set, malware, tool, course-of-action, and relationship. Auxiliary entities such as indicator, identity, report, note, and x-mitre-data-source provide context but do not encode procedural behavior. Table 1 lists the public STIX sources included in the consolidated dataset.

Before qualitative evaluation, we first quantitatively characterize these entities. Attack-pattern objects represent techniques and sub-techniques, with subtechnique-of relationships encoding hierarchy. Tactics are represented by x-mitre-tactic objects and referenced by techniques through the `kill_chain_phases` field. The STIX schema lacks dedicated fields for procedural information; ordering, preconditions, environmental requirements, dependencies, and parameter flows remain in natural-language descriptions and are not machine-readable. For quantitative analysis, each campaign is represented as a binary vector over ATT&CK techniques. We use four metrics that probe complementary aspects of structure: coverage (breadth of documented behavior), sparsity (matrix density), overlap (pairwise reuse), and clustering (pattern cohesion).

Behavioral metrics: Coverage is the fraction of techniques and sub-techniques observed in at least one campaign; sparsity is the proportion of zero entries in the campaign-technique matrix; overlap measures similarity between campaigns by shared techniques; clustering is the stability of structural patterns measured by the *silhouette* coefficient.

The primary dataset for all detailed quantitative analyses is the Enterprise bundle of MITRE ATT&CK in STIX format. This bundle is the main source for structured CTI in this study because it is publicly available, widely adopted, and free of usage restrictions. The additional CTI collections considered here also follow the STIX object model. ATT&CK is the reference for structuring CTI and is widely adopted by defensive platforms and public-sector programs.

We use version 18.1 of the Enterprise bundle as the authoritative source for all quantitative analyses [40]. Additional non-versioned CTI sources were retrieved on 28 November 2025 and frozen for analysis in the companion artifact. Table 1 lists the object counts from each provider. The frozen Enterprise bundle used in measurement is included in the companion artifact. Although several feeds describe themselves as TTP collections, STIX does not define a structured procedure object. Procedural behavior must be reconstructed from contextual relationships such as *uses*, *attributed-to*, *targets*, *delivers*, and *executes*, or from narrative descriptions, especially those in campaign objects. All data and scripts are provided in the companion artifact to ensure full reproducibility.

The Enterprise bundle contains 52 campaign STIX Domain Objects (SDOs), but one (C0033) has no *uses* relationships and is excluded, leaving 51 campaigns. The bundle includes 20,048 relationship objects, of which 17,270 are *uses* relationships relevant to the behavioral links analyzed here. At the attack-pattern layer, the bundle contains 835 ATT&CK technique or sub-technique objects; 144 are revoked or deprecated, leaving 691 active attack-pattern objects. Unless otherwise noted, references to attack-patterns in this paper denote these 691 non-revoked, non-deprecated entries. All quantitative analyses (coverage, sparsity, overlap, clustering,

Table 1: Structured CTI sources in the consolidated dataset. The Enterprise bundle provides the densest campaign-level signal and is the primary target of the quantitative analyses.

Source	Type	Objects	Unique	Duplicates	Description
MITRE Enterprise dataset	Repository	24,771	24,771	0.00%	Broad collection including TTPs, adversaries, and campaigns.
MITRE CAPEC	Repository	2,666	2,666	0.00%	Attack patterns.
DigitalSide	Repository	38,306	38,306	0.00%	Indicators, techniques, relationships, and malware with IOC focus.
AlienVault OTX	TAXII server	17,303	17,303	0.00%	Diverse objects including attack-pattern and threat-actor.
EclecticIQ	TAXII server	2,335	2,043	12.50%	Threat actors, campaigns, and reports.
Total (deduplicated)		85,381	85,089	0.02%	Nearly duplicate-free consolidated dataset.

campaign-group alignment) are computed exclusively on the Enterprise bundle.

We process STIX 2.x objects representing APT groups, campaigns, observed behaviors, infrastructure, and kill-chain elements. The dataset catalogs indicators, tools, techniques, sub-techniques, and their associations with campaigns and intrusion sets. These objects provide structured links but not execution logic, ordering, or temporal constraints. A deduplication analysis using multiple comparison criteria across STIX objects revealed no redundant entries apart from expected duplication in the EclecticIQ source. The consolidated dataset contains 85,089 distinct objects. The source-level duplicate rate reported by EclecticIQ reflects redundancy prior to cross-source consolidation. After object-level deduplication across the composed corpus, those repeated entries are absorbed into the consolidated total, which is why Table 1 reports 0.02% duplicates for the final deduplicated aggregate.

For systematic behavioral analysis and adversary emulation, we restrict the detailed campaign-level analyses to the ATT&CK Enterprise subset. The broader composed corpus is used to characterize ecosystem diversity, cross-source redundancy, and the limits of public STIX structure at large. In our parsed public-source corpus, the Enterprise bundle preserves the richest campaign-level behavioral structure. We therefore use it as the highest-signal public baseline for measuring procedural sufficiency.

5 Methodology

To assess whether structured threat intelligence can be transformed into machine-actionable representations for multi-stage adversary emulation, we adopt a three-stage methodology at an abstract level. The approach is format and platform-agnostic, requiring only structured behavioral entities and explicit relationships. In this work, we instantiate the methodology using STIX 2.x objects and the Caldera framework to demonstrate how each stage maps onto a concrete toolchain.

Figure 2 illustrates the three conceptual stages. Stage 1 performs automated structural conversion of CTI data from STIX to Caldera format, preserving all available descriptions. Stage 2 introduces a translation from abstract behavioral descriptions to minimal executable steps. This translation may be assisted by public templates or language models, but it sometimes needs to be curated and then validated against both the source CTI and the target environment. Stage 3 integrates these steps into an emulation environment. Our implementation fundamentally redefines the role of STIX: instead of serving only as a structured language for describing and sharing

CTI, it becomes a procedural foundation for reconstructing adversary campaigns, turning it into a machine-actionable substrate for executing adversary emulation.

5.1 Stage 1: Automated Structural Modeling

Structured CTI is modeled as a typed behavioral graph, where nodes represent entities such as techniques, campaigns, intrusion sets, malware, and tools, and edges encode relations such as uses, attributed-to, and subtechnique-of. Any CTI representation with typed objects and explicit relationship fields can be normalized into this form. Each behavioral entity is mapped into a uniform internal representation. Techniques or equivalent abstractions are encoded as elements of a fixed behavioral space. Campaigns or long-term threat operations are represented as binary or categorical vectors indicating the presence of relevant techniques. Relationships are translated into vector entries.

Because structured CTI generally lacks explicit temporal or causal ordering, we derive a conservative tactic-ordered list for each campaign or intrusion set by aligning each technique with its associated ATT&CK tactic and placing it along the canonical progression from Reconnaissance to Impact. If a technique maps to multiple tactics via the `kill_chain_phases` field, we assign it to the earliest tactic in this order, breaking ties deterministically using the technique’s external identifier. This ordering serves as an organizational behavior, not as a temporal or causal sequence, and does not introduce procedural semantics absent from the original CTI.

We then apply sequence-comparison analyses to these lists to test whether campaigns exhibit stable, reusable behavioral techniques. Stage 1 converts the STIX format into a procedural format that enables Stage 2 to fill in commands aligned with the technique description and usage, providing intermediate structure to support and guide the subsequent stages.

5.2 Stage 2: Technique Translation Layer

Stage 2 bridges the gap between high-level behavioral descriptions and executable steps. Existing CTI typically states *what* occurred, not *how*, and lacks the procedural semantics needed for automation.

Stage 2 operates on a campaign’s tactic-ordered technique list. For each technique, we extract the behavior implied by the structured representation and check whether public repositories (e.g., Atomic Red Team) offer templates. Language model assistance may be used to draft candidate commands, but these are refined and validated against platform constraints, privilege requirements, and environmental assumptions.

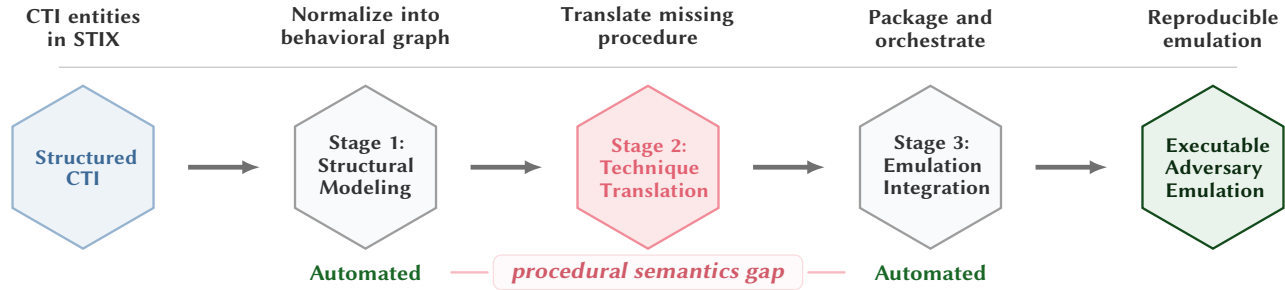


Figure 2: Three-stage methodology from descriptive CTI to executable multi-stage emulation.

The output is an executable step reflecting the intended behavior without contradicting the available intelligence. When parameters, preconditions, or bindings are absent, these are documented explicitly. Lightweight provenance is recorded to maintain traceability between CTI entities and resulting steps. Stage 2 thus produces context-aware executable steps, along with explicit documentation of assumptions and provenance.

A concrete example illustrates this process. In *ShadowRay* campaign, structured CTI and ATT&CK identify T1190 (Exploit Public-Facing Application) and describe abuse of exposed Ray services, but do not specify the endpoint, parameters, or success check required in the laboratory SUT. Stage 2 begins with a generic template or placeholder command, which the analyst then binds to the environment. In our Docker-backed instantiation, this binding led to the concrete command `curl -X POST -F 'cmd=whoami' http://172.21.0.20:5055/exec`. CTI provides the behavioral intent and campaign context, while the analyst adds the specific target address, service, request format, and validation logic. Stage 3 then packages the validated commands for campaign execution.

After candidate commands are drafted, whether from public templates, language-model assistance, or manual translation, the analyst’s role is to validate ordering, environmental assumptions, and parameter binding rather than to reconstruct the behavioral environment from scratch. In the focal workflows, most Stage 2 effort involves binding missing parameters and checking SUT consistency. The required bindings typically fall into recurring categories: target endpoints and ports, command parameters, privilege assumptions, host-local paths or credentials, and validation checks.

5.3 Stage 3: Emulation Integration

Stage 3 converts the translated steps into an executable representation of the adversary. Any emulation environment capable of expressing actions, plans, and controlled execution can instantiate this stage. Each step becomes a platform-aware action with optional preconditions and postconditions. Ordered sets of actions form a behavioral plan that approximates a campaign or long-term threat operation, enabling consistency checks, assumption validation, and telemetry collection.

In this study, we implement Stage 3 using Caldera. We map each translated step (technique or subtechnique) to a Caldera ability, which is an executable unit specifying the command, execution

logic, expected output, and cleanup actions. We then group abilities into Caldera adversary profiles (threat actors or groups) and orchestrate them through Caldera operations (campaigns). Adversary profiles define ordered sets of abilities, while operations manage execution, agent assignment, and logging. Support scripts automate ability ingestion, profile construction, and repeated workflow execution through the REST API. Once we define the steps, the framework automates repetitive emulation tasks.

Overall, this methodology provides a format-agnostic process for transforming descriptive structured CTI into a computable behavioral representation suitable for multi-host adversary emulation.

6 Behavioral Analysis

Our analysis begins from two complementary perspectives. The first is the *composed* STIX dataset, which aggregates several public CTI collections (MITRE ATT&CK Enterprise, CAPEC, Digital-Side, AlienVault OTX, and EclecticIQ). The second is the MITRE ATT&CK Enterprise bundle itself, maintained as the official knowledge base for the Enterprise domain and serialized as STIX 2.x objects.

This distinction is crucial. STIX serves as a generic interchange format that defines object types and relationship structures for CTI, while ATT&CK is a behavioral knowledge base that organizes tactics, techniques, intrusion sets, campaigns, malware, and tools. The Enterprise bundle is a concrete STIX export of this knowledge base, while the composed dataset extends this export with additional feeds that follow the same data model.

We applied our processing pipeline to the composed dataset, parsing all bundles, deduplicating objects, and constructing a typed graph to characterize source diversity, redundancy, and the overall limits of public STIX structure across providers. However, the detailed quantitative analyses reported in this paper cover coverage, sparsity, overlap, clustering, and campaign-group alignment, which are computed exclusively on the chosen bundle (MITRE ATT&CK Enterprise).

For emulation, both the composed dataset and the Enterprise bundle share a fundamental structural limitation: STIX does not define a dedicated procedure object with explicit ordering, preconditions, or environment bindings, and no source in our corpus introduces such a construct as a custom extension. Consistent with prior work on CTI quality, we find that most STIX-encoded artifacts are sparse, incomplete, and procedurally underspecified.

Campaign objects in particular rarely document the full incident, target environment, or execution prerequisites in machine-readable form.

Across the public feeds we parsed, we found that the ATT&CK Enterprise bundle preserves the richest campaign-level structure and therefore serves as the anchor for the detailed behavioral analyses that follow. In our representation, we model each campaign as a binary vector over Enterprise techniques, explicitly indicating which techniques are present. We define intrusion sets analogously, using STIX relationship objects to link intrusion-set and attack-pattern objects. The bundle includes 172 active intrusion sets, 168 have at least one technique relationship and are included in our profile analyses, while we retain the remaining 4 only in the corpus totals.

The Enterprise data documents more threat groups than public campaigns. Each group is associated with one or more sets of techniques spanning phases such as Initial Access, Persistence, Privilege Escalation, Credential Access, Discovery, Lateral Movement, Command and Control, Collection, Exfiltration, and Impact. Together, these techniques form the group’s *operational profile*, supporting activity correlation across campaigns, incident attribution, and behavior-centered defense design.

To assess internal consistency, we compare campaigns to their corresponding intrusion sets within the Enterprise bundle. Because campaign entries are most informative as technique sets, we examine how a campaign’s techniques relate to those attributed to its corresponding intrusion set, using the same Enterprise STIX representation as in clustering and coverage analyses. We also manually cross-checked a sample of these relationships against the ATT&CK website.

This comparison reveals strong asymmetry. Across 22 active campaign–intrusion-set attribution pairs with techniques on both sides, the median Jaccard overlap is only 10.0%, and every pair covers less than half of the linked intrusion-set technique set. This reflects the aggregation of behavior at the intrusion-set level rather than the narrower operational scope of campaigns. Operationally, the linkage is weak: intrusion sets often list far more techniques than are present in any associated campaign documents.

A representative example is the *Juicy Mix* campaign, linked to the *OilRig* intrusion set: 64.3% of the campaign’s techniques appear in OilRig, but only 11.8% of OilRig’s techniques appear in Juicy Mix, as encoded in the Enterprise bundle. Manual cross-checks reveal discrepancies between the downloadable bundle and the website on campaign–intrusion-set relationships, indicating that even frequently updated bundles can diverge from online sources.

We do not attempt to model the source of these mismatches. For emulation, the practical implication is that campaign-group mappings in the downloadable bundle should be treated as curated data that may diverge from the website and may require spot checks in sensitive cases.

The composed dataset (see Section 4) broadens coverage across threat domains and enables cross-checks between providers [22], but does not add procedural depth: all sources rely on the same STIX object model, and none introduces structured fields for ordering, preconditions, or environment bindings. This is why our detailed quantitative analysis and emulation experiments focus

on the Enterprise bundle: in our corpus, it preserves the most campaign-level structure, even if sparse or incomplete.

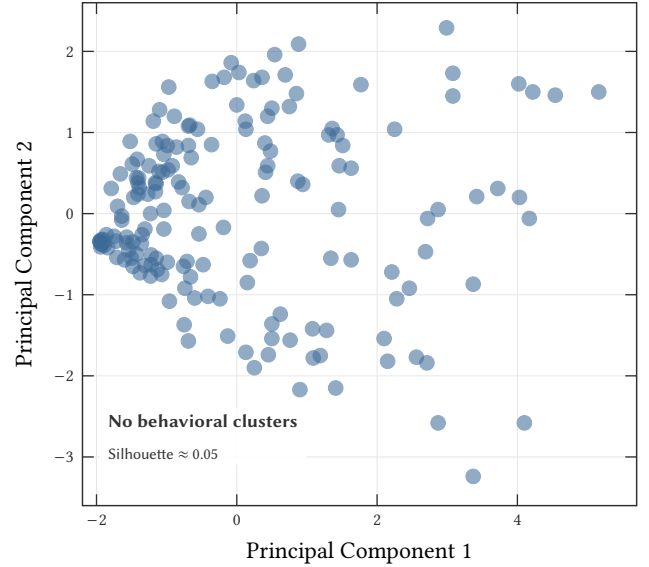


Figure 3: Technique-based similarity of 172 MITRE ATT&CK Enterprise intrusion sets. The dense near-origin distribution indicates limited reusability of techniques across intrusion-sets.

To better understand the behavioral structure in Enterprise intrusion sets, we compute similarities from their technique vectors and apply principal component analysis (PCA) using Jaccard distance on the presence/absence of techniques. PCA makes similarity more meaningful by denoising, decorrelating, and compressing data into its most informative directions. Figure 3 shows that the projection forms a dense near-origin cloud with no distinct families, indicating that intrusion sets do not exhibit coherent behavioral groupings. Instead, each intrusion set comprises a relatively small, idiosyncratic subset of techniques. Although intrusion sets cover more techniques than individual campaigns, they do not provide complete procedures or capture operational context. They are useful for behavioral profiling, but insufficient for direct adversary emulation.

We also investigate whether common behavioral subsequences exist across campaigns. The operational assumption is that, if Enterprise campaigns shared a stable technique backbone, recurring subsequences would appear in tactic-ordered technique lists and could serve as generic emulation templates. For structure, we use the canonical ATT&CK tactic progression for ordering, providing a consistent reconnaissance-to-impact way without claiming to reconstruct the true chronology of any specific incident.

To test whether Enterprise campaigns form reusable behavioral families, we cluster campaign-technique binary vectors and evaluate separation using the silhouette coefficient, where values near zero indicate weak separation. We first apply k -means clustering with Euclidean distance. At $k = 7$, the mean silhouette score is 0.05. As a sparsity-preserving baseline, we generate 1,000 random

binary matrices with the same dimensions and density parameter as the campaign-technique matrix, obtaining a mean silhouette of -0.01 ± 0.01 . These values indicate weak cluster separation in the empirical campaign profiles.

To check whether this result is specific to Euclidean k -means, we repeat the analysis with agglomerative clustering based on Jaccard distance. Sweeping $k \in [2, 10]$ yields consistently low silhouette scores, ranging from 0.03 to 0.05. Together, the Euclidean k -means result, the sparsity-preserving baseline, and the Jaccard agglomerative sweep provide little evidence that Enterprise campaign technique sets organize into stable, reusable behavioral families.

We also test sequence reuse directly. For all $\binom{51}{2} = 1,275$ campaign pairs, we compute the Longest Common Subsequence (LCS) over tactic-ordered technique lists. If campaigns shared a stable procedural backbone, we would expect recurring subsequences long enough to serve as reusable emulation templates. Instead, the mean LCS length is 2.8 techniques (median 2.0, max 29), indicating that shared subsequences are short rather than stable campaign-level chains.

Finally, because tactic ordering is used only to organize techniques, rather than to recover an execution timeline, we randomize valid tactic assignments to test whether the LCS result depends on the specific ordering. Across 200 randomized trials, the mean LCS ranges from 2.728 to 2.754, while the median remains fixed at 2.0. This shows that the absence of long shared subsequences is not driven by the tactic ordering used in the analysis.

These findings are consistent with the weak-cluster picture in Figure 4 and with prior work reporting sparsity, inconsistency, and incomplete behavioral specification in CTI sources [22, 35, 41]. Because tactic-ordered lists represent organizational behavior ordering rather than true timelines, the LCS results should be understood as probes of reusable structure, not as evidence of chronological subsequences. Our negative result does not depend on the tactic-ordered techniques; the same pattern appears in unordered coverage, overlap, and clustering. In practice, the analysis reveals no robust common subsequence between campaigns and no universally shared technique pairs.

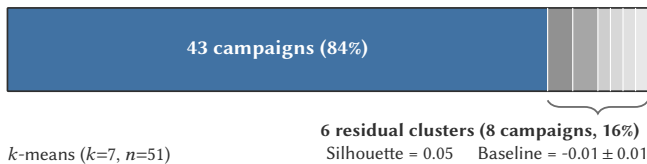


Figure 4: Campaign cluster sizes induced by k -means over technique-overlap vectors. The area chart shows how 51 Enterprise campaigns are partitioned when clustered with $k = 7$, highlighting one dominant cluster and several small residual clusters, rather than well-separated behavioral families.

A common operational assumption is that APT campaigns share a stable behavioral backbone suitable for generating generic emulation profiles. Our analysis of the 51 Enterprise campaigns contradicts this view. Campaign coverage is sparse: only 43.0% of Enterprise techniques appear in at least one campaign, leaving 57.0% unused (Figure 5).

No technique is universal, and even the most frequent ones are far from ubiquitous. The most frequent technique, T1105 (Ingress Tool Transfer), appears in 28 campaigns (55%). No technique appears in every campaign, and no pair co-occurs universally. The frequency distribution is long-tailed, and clusters show low cohesion. Some behaviors, such as T1105, T1588.002, and T1071.001, appear across multiple campaigns, but most techniques are rare.

At the same time, sparseness does not imply indistinguishability. Using positive-evidence identifiability over current Enterprise campaign-technique profiles, we find that all 51 campaigns are distinguishable from one another by some subset of their own techniques, each with a distinguishing witness of size at most 4. Formally, a witness for campaign C is a subset of techniques in C not present in any other campaign profile; we compute the minimum witness exactly over reduced campaign-difference sets using a branch-and-bound search seeded by a greedy upper bound and deterministic lexicographic tie handling.

Even with the limitations noted in earlier work [34] and with a focus only on ATT&CK, intrusion-set profiles remain largely distinguishable. Specifically, 141 out of 187 groups can be identified based on their technique sets; the remaining 46 cases correspond to profiles that are subsumed by larger ones, making unique identification impossible. This finding builds on previous results by showing that distinguishability holds across a much larger set of intrusion sets, rather than only in pairwise group comparisons.

This is a structural result about profile separability, not a claim about attribution or procedural completeness. Under the same model, 145 of 168 non-empty intrusion-set profiles are distinguishable, while 23 are subsumed by larger profiles and admit no positive witness. This is consistent with prior studies reporting structural variability, sparse field usage, and difficulty in extracting actionable temporal structure from public CTI [22, 35, 41].

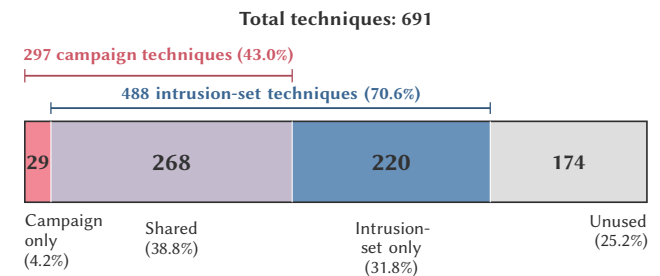


Figure 5: Technique usage across 51 MITRE ATT&CK Enterprise campaigns and 172 intrusion sets.

The main findings are synthesized as follows:

Campaign heterogeneity: Enterprise campaigns employ sparse technique subsets; no technique is universal, and clustering/LCS analyses reveal no common behavioral backbone across campaigns.

Technique dispersion: Only 43.0% of MITRE ATT&CK Enterprise techniques appear in any campaign (Fig. 5), yielding

a long-tailed frequency distribution with no dominant core of shared behavior.

Positive-evidence identifiability: Despite this sparsity, all 51 campaign profiles are distinguishable within the Enterprise corpus by small positive witnesses (all separable by at most four techniques); 145 of 168 intrusion-set profiles are distinguishable, and 23 are subsumed; thus, distinguishability in profile space does not imply executability.

Intrusion-set coverage: Intrusion sets account for 70.6% of Enterprise techniques and preserve broader, less fragmented behavioral profiles than individual campaign objects.

Structural asymmetry: Across 51 campaigns, 297 techniques are used, and 29 do not appear in the corresponding intrusion-set profiles, whereas intrusion sets use 488 techniques, including 220 that appear in no campaign.

Broken campaign-group mapping: Several campaigns are linked to intrusion sets with limited technique overlap, and some campaign technique sets contradict group-level profiles, reflecting inconsistencies between website and Enterprise bundle relationships (e.g., Juicy Mix vs. OilRig).

IOC role: Although IoCs are not the focus of our quantitative analysis, our findings align with prior work that treats indicators mainly as short-lived signals for triage and hunting, rather than as sufficient input for reconstructing multi-step adversary behavior or robust attribution.

7 Emulation Setup

The emulation experiments implement the three-stage methodology in a fully isolated, containerized testbed, using Caldera 5.3.0 exclusively as an execution engine. In Stage 1, relevant intrusion sets, campaigns, and techniques are loaded from the STIX bundle and ordered according to the MITRE ATT&CK canonical tactical order. Stage 2 refines these abstractions into runnable commands through analyst validation, rather than attempting to replay history. Stage 3 executes the translated workflow: Caldera does not interpret STIX objects, infer sequencing, or supply missing parameters. Each translated technique is implemented as a distinct Caldera ability, with a single command and, when appropriate, cleanup logic. Abilities are grouped into adversary profiles based on the Stage 1 information.

The laboratory environment comprises four Docker containers across three private networks: a Caldera server, a Kali execution node, an exposed NGINX service, and an internal database. The Docker artifact provides eight curated adversary workflows, shared service definitions, and a single substrate supporting all experiments. Caldera handles orchestration, while the Kali agent executes technique procedures (see Figure 6). This environment is not intended to replicate historical victim networks, but to provide a controlled, reproducible substrate for evaluating procedural sufficiency.

Campaign-specific bootstrap scripts are preloaded into the shared substrate, enabling all experiments to use a consistent environment. Even multi-host campaigns (e.g., the *Soft Cell* campaign) are implemented on this common substrate; any observed progress or blocking point must be interpreted within this fixed context.

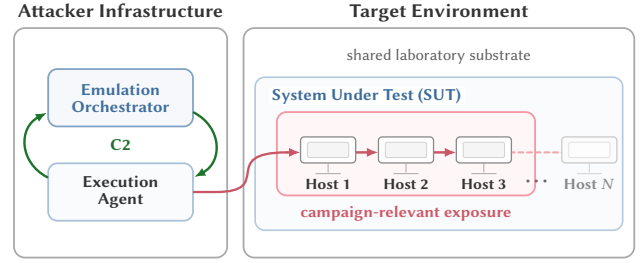


Figure 6: Isolated environment for CTI-derived behavior execution. Left: attacker infrastructure (Caldera orchestrator and Kali agent); right: shared laboratory substrate (system under test) with campaign-relevant exposure highlighted.

Each experiment follows these steps: (1) load and order intrusion sets, campaigns, and techniques (Stage 1); (2) translate techniques into executable commands (Stage 2); (3) prepare the Docker-backed substrate, wait for service and agent readiness, load abilities and adversaries, and create operations (Stage 3); (4) collect operation outputs and execution traces; (5) rebuild the runtime as needed for fresh replay. The same setup is used for the broader audit of all eight curated adversaries.

Figure 7 illustrates the procedural gap for *ShadowRay*: mapping each CTI-derived technique to an executable step requires analyst-supplied parameters (e.g., paths, hostnames, ports), privilege assumptions, environment checks, and operational context.

Within this setup, Caldera executes abilities without framework-side inference. Progress through the chain and the final observed link chain are taken as the execution outcome. Non-success link statuses may disappear as the chain advances; scoring is performed at a quiescent plateau. For each workflow, three outcomes are reported: successful-link count, whether the workflow reaches an explicit end-of-workflow marker (T1529 ability), and whether residual non-zero links remain at a plateau. Across the eight curated adversaries, all workflows reach explicit end markers, none retain non-zero residual links, and the total successful-link count is 109 (median 11, range 7–24).

The artifact automates substrate preparation, service warm-up, workflow execution, and evidence capture. It does not generate procedures from CTI, and the eight-adversary audit should not be interpreted as a causal estimate of how much of each workflow is CTI-derived versus how much is later curated. Rather, it demonstrates that workflows grounded in CTI and completed through analyst-supplied bindings, parameters, and local execution assumptions can yield internally consistent execution chains in a controlled environment.

The emulation experiments also clarify remaining limitations: prerequisites and environmental dependencies must be introduced during translation, and branching or conditional logic cannot be recovered directly from structured CTI. The current ATT&CK Enterprise bundle, serialized in STIX, supports reproducible multi-step enactment only after procedural enrichment is provided using our methodology.

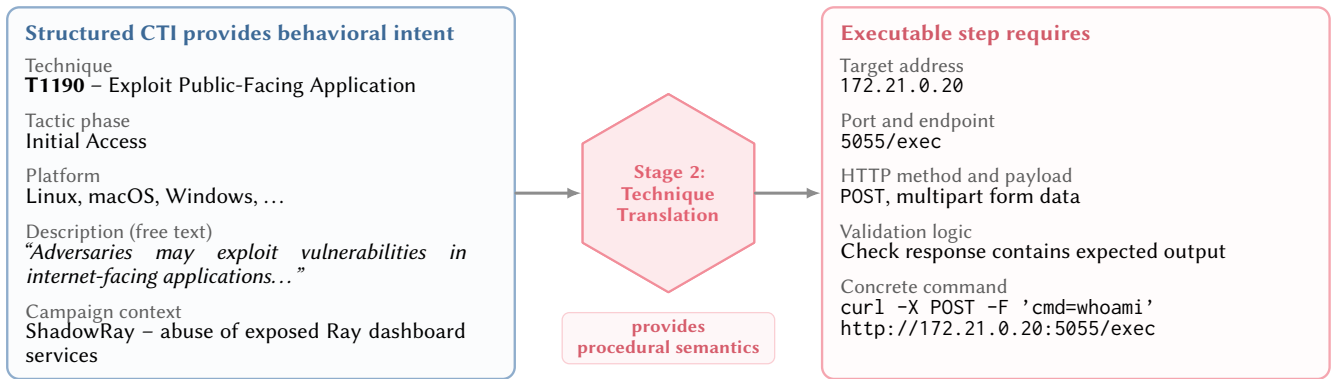


Figure 7: Technique translation for the *ShadowRay* T1190 technique. Structured CTI provides behavioral intent, while Stage 2 translation contributes the procedural semantics required for executable emulation, including concrete parameters, protocol details, environment bindings, and validation logic.

8 Case Studies

Before turning to the focal workflows, we delineate the corpus-wide context in which they operate. Among the 51 MITRE ATT&CK Enterprise campaigns and 172 intrusion sets, 168 intrusion sets (97.7%) have at least one associated technique, while 4 (2.3%) contain no technique relationships. Across the populated intrusion sets, we observe 4362 technique references, for an average of 26.0 techniques per intrusion set. All intrusion sets with at least one technique are included in technique-based measurements.

We applied our methodology to all 691 Enterprise techniques to bound the potential for generic emulation. Of these, 32 are platform-agnostic (e.g., strategic preparation steps with no corresponding OS-level command) and thus cannot be instantiated as executable Caldera abilities on a concrete SUT. The remaining 659 techniques are mapped to single-step Caldera ability representations in our tooling. This corpus-wide mapping establishes representational coverage of how much of the technique space can be mapped to potential actions, not universal cross-platform execution fidelity.

To ground the methodology, we selected one campaign with a directly represented adversary in the Docker artifact (*ShadowRay*) and one multi-host, intrusion-set-derived case study (*Soft Cell*) to assess how much of their documented behavior can be operationalized from structured CTI and where analyst-supplied assumptions remain necessary. The aim is not to reproduce historical intrusions, but to evaluate whether the technique-level behavioral structure encoded in STIX and ATT&CK is sufficient to instantiate coherent, multi-step enactment plans.

ShadowRay involves perimeter exploitation and credential abuse, and the Docker artifact includes a matching adversary workflow, allowing direct observation of execution progress. *Soft Cell*, a multi-year intrusion into telecommunications networks, is represented using GALLIUM intrusion-set material and highlights the additional assumptions needed to reconstruct multi-host procedures. The broader Docker audit complements these focal cases by showing that the same substrate can carry eight curated adversaries to explicit workflow completion, but only on a shared

laboratory substrate, not via independent clean-room replay. Despite differences in scope and tooling, both focal cases expose the same structural limitation: CTI provides behavioral grounding, but typically not a runnable procedure.

For each focal workflow, we extracted relevant techniques from the STIX objects and aligned them with the canonical tactic ordering used throughout this work. Following the methodology of Section 5, each technique was translated into an executable step. Discovery and enumeration actions required only generic commands, whereas steps involving Initial Access, Persistence, Privilege Escalation, and Exfiltration required parameters and assumptions not present in CTI (e.g., file paths, hostnames, credentials, privilege levels).

The evidence supporting our findings extends beyond the two focal cases. It includes corpus-scale structural measurement, corpus-wide technique-to-ability translation coverage, two worked focal cases, and a broader eight-adversary execution audit. Table 2 summarizes each layer. This approach is more informative than a tactic-by-tactic overlap inventory, as each layer clarifies a distinct aspect of the automation boundary.

At the tactic level, the two focal cases overlap in standard APT phases such as Initial Access and Execution, but diverge in persistence, lateral movement, collection, and exfiltration, which depend on environment-specific assumptions. Each translated step was implemented as a single Caldera ability using explicit commands and cleanup logic. In the Docker-backed environment, *ShadowRay* progresses through multiple successful steps and reaches an explicit end marker, but only after providing procedural semantics in Stage 2.

Soft Cell serves as a complementary reconstruction. It demonstrates how multi-host translation quickly accumulates assumptions about hosts, privileges, and routing once the narrative spans multiple hosts. Because Caldera performs no inference or auto-correction, any missing parameter, privilege, ordering dependency, or substrate mismatch surfaces directly as a blocked or unexecutable procedure. Together, the focal cases provide a direct test of procedural completeness.

The results demonstrate how to work around the structural limitations identified in Section 6. The evidence shows that structured CTI provides sufficient behavioral grounding to support

Table 2: Full evidence. Each layer probes a different facet of the procedural-sufficiency question; together, they bound what is structured by CTI and what remains analyst-supplied.

Evidence layer	Scope	Role in the argument	What it demonstrates
Enterprise structural measurement	51 campaigns, 172 intrusion sets (168 with at least one technique relationship), and 691 active Enterprise attack-patterns.	Quantifies coverage, sparsity, overlap, clustering, LCS behavior, and identifiability from structured CTI alone.	Campaigns are sparse and idiosyncratic; intrusion sets are broader but still do not encode executable procedure.
Corpus-wide translation coverage	659 translatable Enterprise techniques after excluding 32 platform-agnostic techniques with no concrete OS-level command.	Bounds how much of the technique space can be represented as single-step Caldera abilities in our tooling.	Establishes representational coverage, not universal cross-platform execution fidelity.
<i>ShadowRay</i> (focal campaign)	Campaign object plus associated ATT&CK techniques; directly represented in the Docker artifact.	Shows how a directly represented campaign becomes runnable after explicit Stage 2 binding.	Direct Docker-backed execution case: once service endpoints, request formats, validation logic, and environment-specific bindings are supplied, the workflow makes reproducible progress and reaches an explicit end marker on the shared substrate.
<i>Soft Cell</i> (focal reconstruction)	Intrusion-set-derived GALLIUM material plus the multi-host telecom intrusion narrative used to reconstruct the procedure.	Shows how multi-host reconstruction accumulates host topology, routing, privilege assumptions, and per-host command binding.	Multi-host reconstruction case: the procedural burden grows quickly when CTI spans several hosts and lacks a machine-readable environment structure.
Eight-adversary Docker audit	Frozen artifact containing eight curated workflows on one shared laboratory substrate.	Broadens execution evidence beyond the focal walkthroughs and exposes substrate-level dependencies in replay.	Corroborating execution breadth: all 8 workflows progress, totaling 109 successful links; all 8 reach explicit end markers; none retain residual non-zero links at plateau. This demonstrates shared-substrate enactment, not isolated campaign replay.

reproducible multi-step enactment when supplemented with a language model translation layer, optionally assisted by an analyst. This demonstrates the methodology on a controlled substrate.

9 Discussion and Implications

Our main result is to remove the ATT&CK-in-STIX usage limitation for emulating adversaries, allowing campaign emulation, evaluation of detection, analytic, and response tools, and red versus blue-team research. We focus on the Enterprise bundle because it preserves the richest campaign-level signal among public feeds; our goal is to test procedural sufficiency where structured information is strongest, not where noise or sparsity dominates.

Quantitatively, campaigns are sparse, heterogeneous, and do not form stable structural clusters. Although every campaign in the current Enterprise bundle is distinguishable from the others by a small positive witness, these campaign objects remain procedurally incomplete. Thus, distinctiveness in profile space is not equivalent to executability.

Operationally, the case studies and Docker-backed audit show that every executable step still depends on explicit assumptions about the target environment, platform constraints, or privilege levels. Only after these missing elements are supplied can workflows make reproducible progress on a controlled laboratory substrate. Thus, our measurements should be interpreted as evidence about the semantic structure explicitly encoded in STIX, not as reconstructions of historical campaign timelines.

This distinction also clarifies why our campaign-side identifiability result does not conflict with Saha et al.’s group-level attribution findings [34]. While they show that many groups lack exclusive technique signatures, we show that Enterprise campaign

profiles can be separable within the bundle, yet still remain procedurally insufficient. Distinctiveness is not the same as executability, and campaign-level separability does not guarantee robust threat-group attribution.

To bound the reducible fraction of manual effort, we audited the Enterprise bundle’s structured fields to identify opportunities for rule-based automation. Stage 1 is fully automatable: `kill_chain_phases` provides tactic ordering and `x_mitre_platforms` defines platform scope, both populated for all 691 active techniques in our dataset.

However, Stage 2 requires parameters, privilege assumptions, and environment bindings that the current export does not provide. The candidate fields for Stage 2 are absent or empty across the active technique set. Thus, a rule-based approach can automate Stage 1, but contributes nothing to Stage 2, which remains dependent on free-text interpretation and environment-specific binding, done by an expert analyst, an LLM, or another strategy.

Free-text descriptions may provide hints, but do not constitute machine-readable procedures with explicit parameters, guards, or execution bindings. As a result, Stage 2 can be analyst-curated after Stage 1 has produced a tactic-aligned order.

Another implication concerns environmental sensitivity. Real intrusions reflect the organization’s topology, identity model, security controls, and operational workflows. Prior work on provenance-based detection [18, 29, 42] demonstrates that behavior is shaped by these environmental constraints. Because STIX does not encode such context, emulations generated solely from CTI risk misrepresenting preconditions or producing unrealistic execution paths unless additional environment modeling is

performed. This limitation is inherent in current CTI standards, which do not encode SUT-level assumptions.

These characteristics have practical consequences for defenders. Once enriched, CTI-derived emulations provide testable approximations of adversary workflows, exposing visibility gaps, validating detection pipelines, and measuring the resilience of analytic rules. Variation in parameters, supporting tools, or execution timing, whether analyst-supplied or LLM-generated, introduces realistic diversity, reducing overfitting to fixed patterns and supporting robust detection evaluation. Structured CTI alone lacks the granularity required to capture this operational diversity.

The gap between descriptive CTI and operational automation also suggests concrete directions for the field. One avenue is to enrich STIX with optional procedural fields, enabling the community to share not just adversary behavior, but also the structure required for reproduction. This does not need to alter the core STIX ontology: optional layers or companion schemas would suffice, and formats like CACAO playbooks [31] and Attack Flow [6] already illustrate sequencing and dependency structures missing from current ATT&CK-in-STIX bundles. These address ordering and flow structure more directly than Enterprise STIX, but still require binding of concrete parameters, privileges, and SUT-local endpoints for a declared laboratory instance.

A second direction is to use LLMs as an intermediate layer to consolidate heterogeneous reports, extract implicit preconditions, propose technique-consistent parameterizations, and generate procedural variants. In our broader development setting, preliminary LLM-assisted command generation occasionally made mistakes that removed the translation boundary but did not clearly execute each technique. LLM-assisted suggestions required analyst curation to correct low-level environment bindings, parameters, and execution details before reliable enactment. A third direction is to build standardized datasets that pair narrative descriptions, CTI objects, and executable steps, enabling benchmarking for extraction pipelines, LLM-assisted emulation, and orchestration frameworks.

More broadly, tighter integration among CTI producers, consumers, and emulation platforms is necessary if structured intelligence is to support red/blue team preparation, continuous control validation, and threat-informed defense. We interpret our results as boundary mapping: quantifying what current structured CTI can support, where its limits remain, and what future machine-actionable CTI would still need to encode. For practitioners, this boundary provides immediate guidance: it tells artifact authors and emulation engineers which parts of a workflow can be grounded in public CTI today, and which still require explicit local reconstruction.

10 Threats to Validity

Behavioral threat emulation is limited because our measurements reflect only the behavioral structure explicitly encoded in STIX objects, rather than the complete ground-truth campaign procedures. Campaign-technique vectors, sparsity, overlap, and clustering capture what structured CTI records, not full execution sequences, causal dependencies, or operational context. Likewise,

the tactic-ordered lists used in our methodology serve as an organizational ordering rather than a true chronology; as such, failed attempts, branching logic, concurrency, and environment-specific constraints remain out of scope.

Internal validity is constrained by data quality and curation practices. Our manual cross-checks showed that the downloadable ATT&CK Enterprise STIX bundle can differ from the website in its campaign-group relationships, leading to incomplete or outdated links in the analyzed snapshot. Public CTI also reflects curation bias: only a subset of known operations is represented in structured form, and documentation quality varies across campaigns and intrusion sets. We mitigate these risks through deterministic parsing, consistent normalization of objects and relationships, validation of counts and links, and manual checks against the authoritative ATT&CK website.

Execution validity is bounded by the laboratory substrate. The Docker artifact runs in a shared, pre-composed environment and requires a fresh setup for each run (i.e., no residual state from previous executions), with Docker containers, the Caldera server, and the Caldera agent all ready before creating operations. We therefore interpret execution outcomes as evidence of procedural progress and blocking points within that substrate, not as proof of independent per-campaign historical replay.

External validity is limited by both the scope of the corpus and the level of environmental abstraction. Our quantitative analysis focuses on the ATT&CK Enterprise dataset because it preserved the strongest campaign-level structure among the public feeds we parsed; it does not cover proprietary sources or establish claims across all STIX collections. The emulation environment is intentionally simplified and designed to test procedural coherence rather than to reproduce historical victim infrastructures. Because STIX does not encode preconditions, parameters, privilege requirements, or environment bindings, the translation step inherently depends on explicit human assumptions. Accordingly, the eight-adversary Docker audit should be interpreted as validating the breadth of the artifact, not as a statistically representative sample of all ATT&CK campaigns.

11 Conclusion

This paper measures the procedural sufficiency of public ATT&CK-in-STIX for adversary emulation. We show that, although the Enterprise bundle provides structured behavioral grounding, it lacks the procedural semantics required for direct multi-stage execution, including ordering, concrete parameters, preconditions, and environment bindings. We then define and instantiate a three-stage methodology that separates automated structural modeling from analyst-curated translation and scripted execution in Caldera, making the automation boundary explicit and reproducible. Across structural analysis, focal case studies, and a Docker-backed audit, the evidence consistently converges on a single conclusion: structured CTI can ground emulation workflows, but cannot operationalize them without explicit procedural enrichment and environment-aware assumptions. These findings establish a reproducible automation boundary for ATT&CK-in-STIX and clarify its role in adversary emulation—as a source of

behavioral grounding rather than a directly executable procedural representation.

References

- [1] Abdullah Alsaheel, Yuhong Nan, Shiqing Ma, Le Yu, Gregory Walkup, Z. Berkay Celik, Xiangyu Zhang, and Dongyan Xu. 2021. ATLAS: A Sequence-based Learning Approach for Attack Investigation. In *Proceedings of the 30th USENIX Security Symposium (USENIX Security '21)*. USENIX Association, Vancouver, BC, Canada, 3005–3022. <https://www.usenix.org/conference/usenixsecurity21/presentation/alsaheel>
- [2] Enes Altinisik, Fatih Deniz, and Hüsrev Taha Sencar. 2023. ProvG-Searcher: A Graph Representation Learning Approach for Efficient Provenance Graph Search. In *Proceedings of the 2023 ACM SIGSAC Conference on Computer and Communications Security (Copenhagen, Denmark) (CCS '23)*. Association for Computing Machinery, New York, NY, USA, 2247–2261. doi:10.1145/3576915.3623187
- [3] Ahmed Aly, Essam Mansour, and Amr Youssef. 2025. OCR-APT: Reconstructing APT Stories from Audit Logs Using Subgraph Anomaly Detection and LLMs. In *Proceedings of the 2025 ACM SIGSAC Conference on Computer and Communications Security (CCS '25)* (Taipei, Taiwan). Association for Computing Machinery, New York, NY, USA, 261–275. doi:10.1145/3719027.3765219
- [4] Frederick Barr-Smith, Xabier Ugarte-Pedrero, Mariano Graziano, Riccardo Spolaor, and Ivan Martinovic. 2021. Survivalism: Systematic Analysis of Windows Malware Living-Off-The-Land. In *2021 IEEE Symposium on Security and Privacy (SP)*. IEEE, Los Alamitos, CA, USA, 1557–1574. doi:10.1109/SP40001.2021.00047
- [5] Marvin Büchel, Tommaso Paladini, Stefano Longari, Michele Carminati, Stefano Zanero, Hodaya Binyamini, Gal Engelberg, Dan Klein, Giancarlo Guizzardi, Marco Caselli, Andrea Continella, Maarten van Steen, Andreas Peter, and Thijs van Ede. 2025. SoK: Automated TTP Extraction from CTI Reports – Are We There Yet?. In *Proceedings of the 34th USENIX Security Symposium (USENIX Security '25) (SEC '25)*. USENIX Association, Seattle, WA, USA, Article 238, 21 pages. <https://www.usenix.org/conference/usenixsecurity25/presentation/buechel>
- [6] Center for Threat-Informed Defense. 2025. Attack Flow v3. <https://ctid.mitre.org/projects/attack-flow> [Online; accessed 2026-03-20].
- [7] Yutong Cheng, Osama Bajaber, Saimon Amanuel Tsegai, Dawn Song, and Peng Gao. 2025. CTINexus: Automatic Cyber Threat Intelligence Knowledge Graph Construction Using Large Language Models. In *Proceedings of the 2025 IEEE 10th European Symposium on Security and Privacy (EuroS&P)*. IEEE, Dublin, Ireland, 923–938. doi:10.1109/EuroSP63326.2025.00057
- [8] Zijun Cheng, Qiujian Lv, Jinyuan Liang, Yan Wang, Degang Sun, Thomas Pasquier, and Xueyuan Han. 2024. Kairos: Practical Intrusion Detection and Investigation using Whole-system Provenance. In *2024 IEEE Symposium on Security and Privacy (SP)*. IEEE, Los Alamitos, CA, USA, 3533–3551. doi:10.1109/SP54263.2024.00005
- [9] ClearSky Cyber Security. 2020. *Fox Kitten: Widespread Iranian Espionage-Offensive Campaign*. Technical Report. ClearSky Cyber Security. <https://www.clearskysec.com/wp-content/uploads/2020/02/ClearSky-Fox-Kitten-Campaign.pdf> Threat intelligence report.
- [10] Suresh K. Damodaran and Paul D. Rowe. 2025. Automated Repeatable Adversary Threat Emulation with Effects Language (EL). arXiv:2510.06420 arXiv:2510.06420.
- [11] Sofia Della Penna, Roberto Natella, Vittorio Orbinato, Lorenzo Parracino, and Luciano Pianese. 2025. CTI-HAL: A Human-Annotated Dataset for Cyber Threat Intelligence Analysis. arXiv preprint arXiv:2504.05866. <https://arxiv.org/abs/2504.05866> Unpublished.
- [12] Gelei Deng, Yi Liu, Víctor Mayoral-Vilches, Peng Liu, Yuekang Li, Yuan Xu, Tianwei Zhang, Yang Liu, Martin Pinzger, and Stefan Rass. 2024. PENTESTGPT: Evaluating and Harnessing Large Language Models for Automated Penetration Testing. In *Proceedings of the 33rd USENIX Security Symposium (Philadelphia, PA, USA) (SEC '24)*. USENIX Association, USA, Article 48, 18 pages. <https://www.usenix.org/conference/usenixsecurity24/presentation/deng>
- [13] Jiangyi Deng, Xinfeng Li, Yanjiao Chen, Yijie Bai, Haiqin Weng, Yan Liu, Tao Wei, and Wenyuan Xu. 2024. RACONTEUR: A Knowledgeable, Insightful, and Portable LLM-Powered Shell Command Explainer. arXiv preprint arXiv:2409.02074. <https://arxiv.org/abs/2409.02074> Unpublished.
- [14] Feng Dong, Shaofei Li, Peng Jiang, Ding Li, Haoyu Wang, Liangyi Huang, Xusheng Xiao, Jiedong Chen, Xiapu Luo, Yao Guo, and Xiangqun Chen. 2023. Are we there yet? An Industrial Viewpoint on Provenance-based Endpoint Detection and Response Tools. In *Proceedings of the 2023 ACM SIGSAC Conference on Computer and Communications Security (Copenhagen, Denmark) (CCS '23)*. Association for Computing Machinery, New York, NY, USA, 2396–2410. doi:10.1145/3576915.3616580
- [15] Feng Dong, Liu Wang, Xu Nie, Fei Shao, Haoyu Wang, Ding Li, Xiapu Luo, and Xusheng Xiao. 2023. DISTDET: A Cost-Effective Distributed Cyber Threat Detection System. In *Proceedings of the 32nd USENIX Security Symposium (USENIX Security '23)*. USENIX Association, Anaheim, CA, USA, 6575–6592. <https://www.usenix.org/conference/usenixsecurity23/presentation/dong-feng>
- [16] FireEye Threat Intelligence. 2019. *Double Dragon: APT41, a Dual Espionage and Cyber Crime Operation*. Technical Report. FireEye. <https://cloud.google.com/blog/topics/threat-intelligence/apt41-dual-espionage-and-cyber-crime-operation> Threat intelligence report.
- [17] Ryan Gabrys, Mark Bilinski, Sunny Fugate, and Daniel Silva. 2024. Using Natural Language Processing Tools to Infer Adversary Techniques and Tactics under the Mitre ATT&CK Framework. In *Proceedings of the 2024 IEEE 14th Annual Computing and Communication Workshop and Conference (CCWC)*. IEEE, Las Vegas, NV, USA, 541–547. doi:10.1109/CCWC60891.2024.10427746
- [18] Xueyuan Han, Thomas Pasquier, Adam Bates, James W. Mickens, and Margo I. Seltzer. 2020. UNICORN: Runtime Provenance-Based Detector for Advanced Persistent Threats. In *Proceedings of the 27th Annual Network and Distributed System Security Symposium (NDSS)*. The Internet Society, San Diego, CA, USA, –. doi:10.14722/ndss.2020.24046
- [19] Md Nahid Hossain, Sanaz Sheikh, and R. Sekar. 2020. Combating Dependence Explosion in Forensic Analysis Using Alternative Tag Propagation Semantics. In *2020 IEEE Symposium on Security and Privacy (SP)*. IEEE, Los Alamitos, CA, USA, 1139–1155. doi:10.1109/SP40000.2020.00064
- [20] Zian Jia, Yun Xiong, Yuhong Nan, Yao Zhang, Jinjing Zhao, and Mi Wen. 2024. MAGIC: Detecting Advanced Persistent Threats via Masked Graph Representation Learning. In *33rd USENIX Security Symposium (USENIX Security '24)*. USENIX Association, Philadelphia, PA, USA, 5197–5214. <https://www.usenix.org/conference/usenixsecurity24/presentation/jia-zian>
- [21] Peng Jiang, Ruizhe Huang, Ding Li, Yao Guo, Xiangqun Chen, Jianhai Luan, Yuxin Ren, and Xinwei Hu. 2023. Auditing Frameworks Need Resource Isolation: A Systematic Study on the Super Producer Threat to System Auditing and Its Mitigation. In *Proceedings of the 32nd USENIX Security Symposium (USENIX Security '23)*. USENIX Association, Anaheim, CA, USA, 355–372. <https://www.usenix.org/conference/usenixsecurity23/presentation/jiang-peng>
- [22] Beomjin Jin, Eunsoo Kim, Hyunwoo Lee, Elisa Bertino, Doowon Kim, and Hyounghick Kim. 2024. Sharing Cyber Threat Intelligence: Does It Really Help?. In *Proceedings of the 31st Annual Network and Distributed System Security Symposium (NDSS)*. Internet Society, San Diego, CA, USA, –. <https://dx.doi.org/10.14722/ndss.2024.24228>
- [23] Joseph Khoury, Dorde Klisura, Hadi Zanddzari, Gonzalo De La Torre Parra, Peyman Najafirad, and Elias Bou-Harb. 2024. Jbeil: Temporal Graph-Based Inductive Learning to Infer Lateral Movement in Evolving Enterprise Networks. In *Proceedings of the 2024 IEEE Symposium on Security and Privacy (SP)*. IEEE, San Francisco, CA, USA, 3644–3660. doi:10.1109/SP54263.2024.00009
- [24] Isaiah J. King and H. Howie Huang. 2023. Euler: Detecting Network Lateral Movement via Scalable Temporal Link Prediction. *ACM Transactions on Privacy and Security* 26, 3, Article 35 (June 2023), 36 pages. doi:10.1145/3588771
- [25] Shaofei Li, Feng Dong, Xusheng Xiao, Haoyu Wang, Fei Shao, Jiedong Chen, Yao Guo, Xiangqun Chen, and Ding Li. 2024. NODLINK: An Online System for Fine-Grained APT Attack Detection and Investigation. In *Proceedings of the 31st Annual Network and Distributed System Security Symposium (NDSS)*. Internet Society, San Diego, CA, USA, –. doi:10.14722/ndss.2024.23204 Online; pages not assigned.
- [26] Mingqi Lv, Hongzhe Gao, Xuebo Qiu, Tieming Chen, Tiantian Zhu, Jinyin Chen, and Shouling Ji. 2024. TREC: APT Tactic / Technique Recognition via Few-Shot Provenance Subgraph Learning. In *Proceedings of the 2024 ACM SIGSAC Conference on Computer and Communications Security (Salt Lake City, UT, USA) (CCS '24)*. Association for Computing Machinery, New York, NY, USA, 139–152. doi:10.1145/3658644.3690221
- [27] Mandiant Consulting. 2025. *Google Cloud Security 2025 Report: M-Trends*. Technical Report. Mandiant, Google Cloud Security. <https://services.google.com/fh/files/misc/m-trends-2025-en.pdf> Threat intelligence report.
- [28] Yuhang Meng, Shaofei Li, Jiaping Gui, Peng Jiang, and Ding Li. 2025. KnowHow: Automatically Applying High-level CTI Knowledge for Interpretable and Accurate Provenance Analysis. arXiv:2509.05698 arXiv:2509.05698.
- [29] Sadeq M. Milajerdi, Rigel Gjomemo, Birhanu Eshete, R. Sekar, and V. N. Venkatakrishnan. 2019. HOLMES: Real-Time APT Detection through Correlation of Suspicious Information Flows. In *2019 IEEE Symposium on Security and Privacy (SP)*. IEEE, Los Alamitos, CA, USA, 1137–1152. doi:10.1109/SP.2019.00026
- [30] OASIS CTI Technical Committee. 2021. STIX Version 2.1: Committee Specification 02. <https://docs.oasis-open.org/cti/stix/v2.1/stix-v2.1.html> [Online; accessed 2024-06-01].
- [31] OASIS Open. 2023. CACAO Security Playbooks Version 2.0. <https://docs.oasis-open.org/cacao/security-playbooks/v2.0/security-playbooks-v2.0.html> [Online; accessed 2026-03-20].
- [32] Vittorio Orbinato, Marco Carlo Feliciano, Domenico Cotroneo, and Roberto Natella. 2024. Laccolith: Hypervisor-based Adversary Emulation with Anti-detection. *IEEE Transactions on Dependable and Secure Computing* 21, 6 (2024), 5374–5387. <https://doi.ieeecomputersociety.org/10.1109/TDSC.2024.3376129>
- [33] Wei Qiao, Yebo Feng, Teng Li, Zhuo Ma, Yulong Shen, Jianfeng Ma, and Yang Liu. 2025. Slot: Provenance-Driven APT Detection through Graph Reinforcement

- Learning. In *Proceedings of the 2025 ACM SIGSAC Conference on Computer and Communications Security (CCS '25)* (Taipei, Taiwan). Association for Computing Machinery, New York, NY, USA, 963–977. doi:10.1145/3719027.3744788
- [34] Aakanksha Saha, Martina Lindorfer, and Juan Caballero. 2026. Kitten or Panda? Measuring the Specificity of Threat Group Behaviors in Public CTI Knowledge Bases. In *Proceedings of the ACM Asia Conference on Computer and Communications Security (ASIA CCS '26)*. ACM, Bangalore, India, 15. doi:10.1145/3779208.3786258
- [35] Kiavash Satvat, Rigel Gjomemo, and V. N. Venkatakrishnan. 2021. Extractor: Extracting Attack Behavior from Threat Reports. In *2021 IEEE European Symposium on Security and Privacy (EuroS&P)*. IEEE, Los Alamitos, CA, USA, 598–615. doi:10.1109/EuroSP51992.2021.00046
- [36] Xiangmin Shen, Zhenyuan Li, Graham Burleigh, Lingzhi Wang, and Yan Chen. 2024. Decoding the MITRE Engenuity ATT&CK Enterprise Evaluation: An Analysis of EDR Performance in Real-World Environments. In *Proceedings of the 19th ACM Asia Conference on Computer and Communications Security* (Singapore, Singapore) (ASIA CCS '24). Association for Computing Machinery, New York, NY, USA, 96–111. doi:10.1145/3634737.3645012
- [37] Xiangmin Shen, Lingzhi Wang, Zhenyuan Li, Yan Chen, Wencheng Zhao, Dawei Sun, Jiahui Wang, and Wei Ruan. 2025. PentestAgent: Incorporating LLM Agents to Automated Penetration Testing. In *Proceedings of the 20th ACM Asia Conference on Computer and Communications Security (ASIA CCS '25)*. Association for Computing Machinery, New York, NY, USA, 375–391. doi:10.1145/3708821.3733882
- [38] Brian Singer, Keane Lucas, Lakshmi Adiga, Meghna Jain, Lujo Bauer, and Vyas Sekar. 2025. InCALMO: An Autonomous LLM-assisted System for Red Teaming Multi-Host Networks. arXiv preprint arXiv:2501.16466. <https://arxiv.org/abs/2501.16466> Unpublished.
- [39] Brian Singer, Yusuf Saquib, Lujo Bauer, and Vyas Sekar. 2025. Perry: A High-level Framework for Accelerating Cyber Deception Experimentation. arXiv preprint arXiv:2506.20770. <https://arxiv.org/abs/2506.20770> Unpublished.
- [40] Blake E Strom, Andy Applebaum, Doug P Miller, Kathryn C Nickels, Adam G Pennington, and Cody B Thomas. 2020. MITRE ATT&CK: Design and Philosophy. Technical Report. The MITRE Corporation, McLean, VA, USA, 46 pages. https://attack.mitre.org/docs/ATTACK_Design_and_Philosophy_March_2020.pdf
- [41] Nan Sun, Ming Ding, Jiaojiao Jiang, Weikang Xu, Xiaoxing Mo, Yonghang Tai, and Jun Zhang. 2023. Cyber Threat Intelligence Mining for Proactive Cybersecurity Defense: A Survey and New Perspectives. *IEEE Communications Surveys & Tutorials* 25, 3 (2023), 1748–1774. doi:10.1109/COMST.2023.3273282
- [42] Mati Ur Rehman, Hadi Ahmadi, and Wajih Ul Hassan. 2024. Flash: A Comprehensive Approach to Intrusion Detection via Provenance Graph Representation Learning. In *2024 IEEE Symposium on Security and Privacy (SP)*. IEEE, Los Alamitos, CA, USA, 3552–3570. doi:10.1109/SP54263.2024.00139
- [43] Mathew Vermeer, Michel van Eeten, and Carlos Gañán. 2022. Ruling the Rules: Quantifying the Evolution of Rulesets, Alerts and Incidents in Network Intrusion Detection. In *Proceedings of the 2022 ACM on Asia Conference on Computer and Communications Security (Nagasaki, Japan) (ASIA CCS '22)*. Association for Computing Machinery, New York, NY, USA, 799–814. doi:10.1145/3488932.3517412
- [44] Caio M. C. Viana, Carlos H. G. Ferreira, Fabricio Murai, Aldri Luiz Dos Santos, and Lourenço Alves Pereira Júnior. 2024. Devil in the Noise: Detecting Advanced Persistent Threats with Backbone Extraction. In *2024 IEEE Symposium on Computers and Communications (ISCC)*. IEEE, Los Alamitos, CA, USA, 1–7. doi:10.1109/ISCC61673.2024.10733665
- [45] Apurva Virkud, Muhammad Adil Inam, Andy Riddle, Jason Liu, Gang Wang, and Adam Bates. 2024. How Does Endpoint Detection Use the MITRE ATT&CK Framework?. In *33rd USENIX Security Symposium (USENIX Security '24)*. USENIX Association, Philadelphia, PA, 3891–3908. <https://www.usenix.org/conference/usenixsecurity24/presentation/virkud>
- [46] Jian Wang, Tiantian Zhu, Chunlin Xiong, and Yan Chen. 2024. MultiKG: Multi-source Threat Intelligence Aggregation for High-quality Knowledge Graph Representation of Attack Techniques. arXiv:2411.08359 arXiv:2411.08359.
- [47] Lingzhi Wang, Zhenyuan Li, Yi Jiang, Zhengkai Wang, Zonghan Guo, Jiahui Wang, Yangyang Wei, Xiangmin Shen, Wei Ruan, and Yan Chen. 2024. From Sands to Mansions: Towards Automated Cyberattack Emulation with Classical Planning and Large Language Models. arXiv:2407.16928 arXiv:2407.16928.
- [48] Ming Xu, Hongtai Wang, Jiahao Liu, Yun Lin, Chenyang Xu, Yingshi Liu, Hoon Wei Lim, and Jin Song Dong. 2024. ThreatPilot: Attack-Driven Threat Intelligence Extraction. arXiv preprint arXiv:2412.10872. <https://arxiv.org/abs/2412.10872> Unpublished.
- [49] Fan Yang, Jiachen Xu, Chunlin Xiong, Zhou Li, and Kehuan Zhang. 2023. PROGRAPHER: An Anomaly Detection System Based on Provenance Graph Embedding. In *Proceedings of the 32nd USENIX Security Symposium (USENIX Security '23)*. USENIX Association, Anaheim, CA, USA, 4355–4372. <https://www.usenix.org/conference/usenixsecurity23/presentation/yang-fan>
- [50] Le Yu, Shiqing Ma, Zhuo Zhang, Guanhong Tao, Xiangyu Zhang, Dongyan Xu, Vincent E. Urias, Han Wei Lin, Gabriela F. Ciocarlie, Vinod Yegneswaran, et al.

2021. ALchemist: Fusing Application and Audit Logs for Precise Attack Provenance without Instrumentation. In *Proceedings of the Network and Distributed System Security Symposium (NDSS)*. Internet Society, San Diego, CA, USA, –. <https://dx.doi.org/10.14722/ndss.2021.24445>

- [51] Bo Zhang, Yansong Gao, Changlong Yu, Boyu Kuang, Zhi Zhang, Hyoungshick Kim, and Anmin Fu. 2025. TAPAS: An Efficient Online APT Detection with Task-guided Process Provenance Graph Segmentation and Analysis. In *Proceedings of the 34th USENIX Security Symposium (USENIX Security '25)*. USENIX Association, Seattle, WA, USA, 607–624. <https://www.usenix.org/conference/usenixsecurity25/presentation/zhang-bo-tapas>

A Use of Generative AI Tools

The authors used Grammarly and ChatGPT for grammar checking, limited editorial revision, and minor formatting assistance for figures and illustrations. All scientific claims, analyses, experiments, visual representations, and conclusions were produced and verified by the authors.

B Open Science

The companion artifact provides two reproducibility paths. The first reruns the structural measurements, refreshes the frozen execution summaries, rebuilds the manuscript, and executes the measurement test suite from a clean runtime context. The second optionally reconstructs the shared-substrate laboratory environment and replays the frozen eight-workflow package. As in the main text, we treat the latter as a shared-substrate execution audit rather than as campaign-isolated historical replay.

The artifact also preserves the composed multi-source STIX corpus used for ecosystem-level parsing and deduplication, as well as the frozen Enterprise subset used for all detailed campaign-level measurements and emulation-facing analyses.

For reviewer-sensitive claims, the artifact exposes compact provenance records covering the Docker workflow parity checks, the structured-field audit, the positive-witness identifiability claims, the clustering and LCS robustness probes, and the appendix-level aggregate values used in the paper. Together, these materials support the field-population counts, identifiability results, robustness analyses, and Docker-audit totals reported in the manuscript.

The released identifiability implementation reproduces the exact witness-search procedure described in Section 6, including the reduced-difference construction, greedy upper bound, and branch-and-bound pruning.

C Automation-Relevant Field Population

Table 3 summarizes the structured-field audit over the 691 active Enterprise attack-patterns used in this study. Here, *Present* means that the raw STIX field exists in the frozen Enterprise v18.1 bundle snapshot, whereas *Non-empty* means that the field contains machine-readable content usable by the rule-based baseline used in Section 9. Under this criterion, Stage 1 fields are populated, while the candidate Stage 2 fields are absent or contain no machine-actionable content in the current export.

In particular, `x_mitre_detection` is present as a raw field in the bundle, but under this baseline, it contributes no machine-readable parameter, guard, ordering, or environment-binding information; accordingly, its non-empty count is zero.

Table 3: Structured-field audit behind the rule-based automation baseline.

Field	Present	Non-empty
kill_chain_phases	691	691
x_mitre_platforms	691	691
x_mitre_system_requirements	0	0
x_mitre_detection	691	0
x_mitre_data_sources	0	0
x_mitre_permissions_required	0	0

D Supplementary Set-Based Reuse Probe

To complement the tactic-ordered LCS analysis with an order-free probe, we compute for each itemset size $k \in \{1, \dots, 5\}$ the maximum support of any k -technique itemset across the 51 Enterprise campaigns. The rapid decay in Table 4 reinforces the same conclusion as the clustering and LCS results: campaigns share small recurring fragments, but not a dominant reusable backbone.

Table 4: Maximum support of any unordered technique itemset across the 51 Enterprise campaigns.

Itemset size	Max support	Campaign share
1	28	54.9%
2	17	33.3%
3	10	19.6%
4	7	13.7%
5	6	11.8%

E Supplementary Docker Audit Outcomes

Table 5 lists the per-workflow outcomes behind the eight-workflow Docker audit summarized in Section 7. The main text relies on the aggregate boundary result; the per-workflow counts remain here for auditability and artifact cross-checking.

Table 5: Observed outcomes for the eight curated workflows in the Docker audit.

Workflow	Links	End marker	Residual
APT41 DUST	24	Yes	0
C0010	10	Yes	0
C0026	7	Yes	0
CostaRicto	11	Yes	0
Operation MidnightEclipse	18	Yes	0
Outer Space	9	Yes	0
Salesforce Data Exfiltration	19	Yes	0
ShadowRay	11	Yes	0